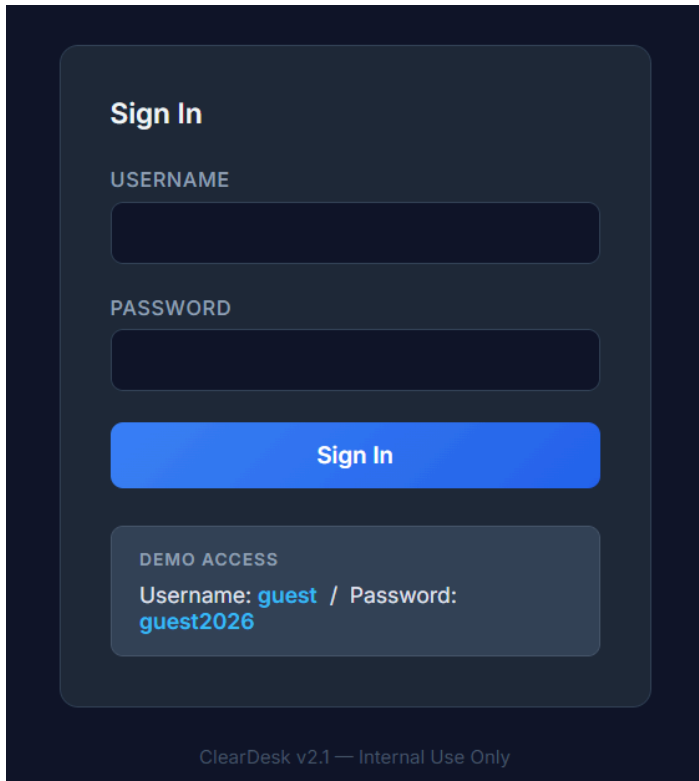


Lab: <https://hackerdna.com/labs/cleardesk>

User: ReaperBlitz

Section 1: User Flag

1. First, you will find this login form.



The image shows a login form for 'ClearDesk v2.1'. It has a dark blue background. The form is titled 'Sign In' in white. Below the title are two input fields: 'USERNAME' and 'PASSWORD'. Below these fields is a blue 'Sign In' button. At the bottom of the form, there is a section for 'DEMO ACCESS' with the text 'Username: guest / Password: guest2026'. At the very bottom of the page, it says 'ClearDesk v2.1 — Internal Use Only'.

Log in with the following credentials shown below:

Username: guest

Password: guest2026

2. Then, you will see these tickets.

Your Tickets				
ID	SUBJECT	PRIORITY	STATUS	CREATED
#2	WiFi not working in Conference Room B	MEDIUM	open	2026-03-09
#3	Request: New monitor for workstation	LOW	pending	2026-03-09

Click on one

The URL will show “*TARGET-IP/api/ticket/...*” Now, from that URL, we can suspect an attack surface for IDOR (Insecure Direct Object Reference), but this isn’t a confirmed vulnerability yet, so we need to test by inputting the URL of “*TARGET-IP/api/ticket/1*”, and then we can find the user flag.

Section 2: Root Flag

1. Now, for this section, we will go over finding the root flag. So the first step is to identify how many tickets there are, as there can be many. We test it by inputting the URL directory of */api/ticket/10*, then we will see this.

```
{"error": "Ticket not found"}
```

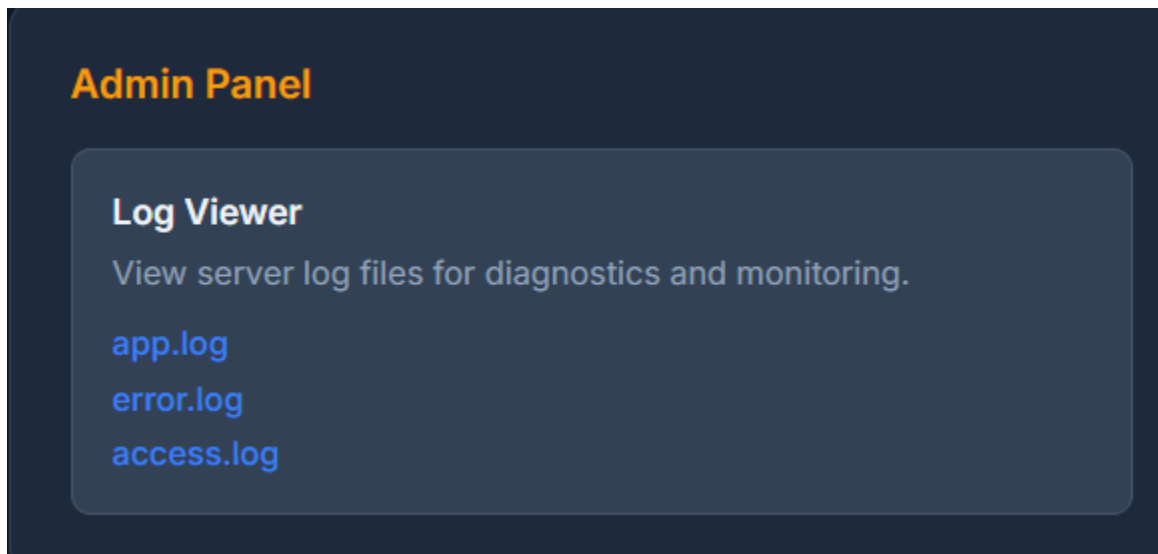
Which likely means it's below 10, so we try */api/ticket/9*, and it shows the same error so we try *api/ticket/8* and we see these

```
{"created": "2026-03-09T16:45:00Z", "description": "Temporary admin password has been reset per policy. New credentials: admin / Cl3arD3sk_Adm1n_2026. Please change after first login.\n\nAlso: the nightly backup job is failing to read /root/flag-root.txt (permission denied). Please check file permissions after login. \u20142014 IT Security Team", "id": 8, "owner_id": 1, "priority": "high", "status": "resolved", "subject": "Password Reset: Admin Portal Access"}
```

And then we see the admin login credentials.

2. Log out and log in with the admin credentials shown on */api/ticket/8*

3. Now in the admin dashboard, we see



Try to click into one of the logs, and you will see the URL of <http://TARGET-IP/admin/logs?file=app.log>

Now we will see some possible Path Traversal Vulnerability (CWE-22 or CWE-23). Now we can use that vulnerability and read the root flag. We see on *api/tickets/8* that the flag is in */flag/flag-root.txt*, so we try that path and input it as <http://TARGET-IP/admin/logs?file=/root/flag-root.txt>
And we find the root flag.

Section 3: Summary

From this lab, we can acquire the following skills.

IDOR (Insecure Direct Object Reference), API Security, Path Traversal, Access Control, and Privilege Escalation

Thank you!